

GovSecure AI Chef™

Enterprise AI Governance Recipe Matrix Toolkit

Paid SMB Edition | Client-ready operational toolkit

Who it is for Small and mid-sized businesses adopting AI without a large governance team.	What it gives you A practical operating model, templates, sample data, and a maturity path from 24 core recipes to 36.
Design style Creative-enterprise: polished enough to sell, practical enough to run.	How to use it Start with intake and ownership. Then register systems, tier risk, map controls, monitor, and review quarterly.

Positioning statement

Turn scattered AI policies into a working system with assigned owners, risk tiers, control expectations, and evidence that leadership can actually review.

Version v1.1	Recipes 24 core	Roadmap 36 in v2.0
-------------------------------	----------------------------------	-------------------------------------

1. Executive Overview

What AI Chef is

GovSecure AI Chef™ is a branded operating model for SMB AI governance. It converts AI risk, control, ownership, and assurance into a recipe system that busy operators can actually use.

Why SMBs need this

- SMBs are adopting AI faster than they are defining ownership, review paths, and acceptable uses.
- Most governance materials are either too abstract for operations or too enterprise-heavy for lean teams.
- Paid buyers want something they can drop into a live program without needing a six-week translation exercise.

Primary buyer profile

SMB owners, operators, and lean technology or compliance leaders who need AI guardrails without building a giant bureaucracy.

What the paid edition adds

- Realistic sample data so teams understand what good looks like.
- Template pages with clear required fields, review cycles, and evidence expectations.
- Appendices that make the toolkit feel implementation-ready rather than decorative.

2. Five-step adoption flow

1	2	3	4	5
Identify	Assess	Assign	Control	Review

3. 24 Core Recipe Matrix

Six stations. Four live recipes per station. Two reserved upgrade slots per station for the v2.0 expansion path.

Station	Active recipes	Upgrade path
Foundation & Ownership	• Head Chef Assignment • Kitchen Rules • Role Recipe Card • Approved Menu Only	2 reserved advanced slots
Data & Knowledge Controls	• Clean Ingredients • Source Provenance Check • Retention & Disposal Recipe • Knowledge Base Boundaries	2 reserved advanced slots
Model & Tool Safety	• Pre-Serve Evaluation • Secret Sauce Lockdown • Drift Tasting • Vendor Pantry Review	2 reserved advanced slots
Agent & Automation Controls	• Tool Permission Gate • Human Before High Impact • Sandbox Before Service • Kill Switch on the Counter	2 reserved advanced slots
Decision & Human Oversight	• Explain the Dish • Escalate Ambiguous Orders • Bias & Fairness Taste Test • High-Risk Use Case Flag	2 reserved advanced slots
Assurance, Monitoring & Response	• Full Kitchen Inventory • Kitchen Camera Logs • Burn Response Plan	2 reserved advanced slots

	• Quarterly Recipe Review	
--	---------------------------	--

4. Ownership Model and RACI

Sample SMB scenario: HarborCraft Home Goods

A 280-person ecommerce and operations business using Microsoft Copilot, ChatGPT Enterprise, Zendesk AI, and two workflow automations connected to customer support and internal knowledge.

Accountability model

Role	Sample owner	What they own
Executive Sponsor	COO	Approves policy direction, high-risk exceptions, and quarterly review decisions.
AI Governance Lead	Head of Risk & Security	Runs intake, control mapping, registry reviews, and evidence collection.
Business Owner	Support Director / Ops Lead	Owns use-case outcomes, human oversight, and process performance.
IT / Platform Owner	IT Manager	Handles provisioning, connector controls, logging, and technical operations.
Legal / Privacy	External counsel + privacy lead	Reviews data use, notices, and high-impact legal/privacy triggers.
Procurement / Vendor Risk	Finance & Ops Manager	Tracks vendor diligence, contract terms, and dependency issues.

RACI sample across five core tasks

Activity	EX	AG	IT	BU	Notes
Approve high-risk use case	A	R	C	C	Legal/Privacy join as needed
Maintain AI registry	I	A	R	C	Reviewed monthly
Enable logging and connector controls	I	C	A/R	C	Security evidence retained

Quarterly governance review	A	R	C	C	Top risks + exceptions
Pause harmful automation	I	C	A/R	C	Emergency switch with post-review

5. AI Use Case Intake and Risk Tiering

Realistic sample intake

Use case: Customer support co-pilot that drafts responses, summarizes tickets, and suggests refund options to human agents.

Field	Example entry
Business purpose	Reduce average ticket handling time by 20% while keeping a human agent in the loop.
Users	Support agents and team leads.
Data used	Customer emails, order history, product knowledge base, refund policy snippets.
External impact	Customer-facing outputs may be sent after agent approval.
Decision type	Recommendations only; no autonomous refunds.
Regulatory relevance	Privacy review required because customer data and retention are involved.
Human oversight	Mandatory agent approval before send or action.
Proposed risk tier	Tier 2 - Moderate, with Tier 3 controls if refund automation is later enabled.

Risk tier logic

- Tier 1 - Low: internal productivity, low sensitivity, no external decision effect.
- Tier 2 - Moderate: business process support, limited customer or employee impact, strong human review.
- Tier 3 - High: meaningful operational, legal, HR, financial, or customer impact; enhanced review required.
- Tier 4 - Prohibited / Executive review: disallowed use or activity requiring executive decision and documented exception.

6. AI System Registry - realistic examples

System	Biz owner	Tech owner	Vendor	Use case	Tier	Status	Review
ChatGPT Enterprise	Marketing Director	IT Manager	OpenAI	Draft campaigns and summarize research	Tier 2	Approved	Monthly
Microsoft Copilot	COO	IT Manager	Microsoft	Internal productivity and meeting summaries	Tier 1	Approved	Quarterly
Zendesk AI Assist	Support Director	Support Systems Lead	Zendesk	Ticket drafting and response suggestions	Tier 2	Approved	Monthly
Refund Risk Agent (pilot)	Support Director	Automation Engineer	Custom + Azure OpenAI	Suggest refund risk labels before human approval	Tier 3	Pilot only	Bi-weekly
Vendor Contract Review GPT	Finance & Ops Manager	Security Manager	Anthropic via platform	Draft clause summaries for procurement	Tier 2	Approved with restrictions	Quarterly

Registry rule of thumb

If a team can name the AI tool but cannot name the owner, review cycle, or permitted use, the registry entry is not complete. That gap is usually where risk starts breeding.

7. Policy-to-Control Mapping

Policy area	Statement	Required control	Evidence
Acceptable use	Teams may use approved AI tools for low and moderate-risk tasks only.	Approved tools list + intake form	Screenshots, approvals, training record
Prohibited use	No autonomous legal, HR, or financial commitments without explicit approval.	Tier 4 gate + exception log	Exception register
Human oversight	Human review is required before customer-facing send or high-impact action.	HITL checkpoints	Workflow screenshot / SOP
Vendor review	No new AI vendor enters production without diligence.	Vendor review checklist	Security + legal review pack
Data handling	Sensitive data must follow classification and approved retention rules.	Connector boundaries + retention config	Config export / policy
Logging	Prompt, action, and decision evidence must be logged where feasible.	Log sources and quarterly review	Sample log + review deck
Incident escalation	AI incidents follow the same containment and review discipline as security incidents.	AI incident playbook	Incident ticket + RCA
Change management	Material changes to models, connectors, or permissions must be reviewed.	Change request workflow	Change ticket

8. Monitoring, Logging, and AI Incident Response

- Monitor drift, misuse, access changes, exceptions, and failed or unusual automated actions.
- Review logs on a defined cadence rather than waiting for the fancy disaster to announce itself.
- Treat harmful outputs, privacy leaks, and connector misuse as operational incidents with owners and evidence.

Recommended incident categories

- Harmful output
- Privacy breach
- Security exposure
- Model or prompt drift
- Unauthorized automation
- Third-party service failure

Reusable page structure preview



Toolkit Page Template

Reusable layout for each recipe, control, checklist, or control page — v1.0

Use this page structure to document any recipe, control, checklist, or governance standard.

	Page Title Enter page title		Page Code ABC-00X		Station Select station
	Primary Owner Enter owner		Risk Tier Low / Med / High		Review Cycle e.g., Annual

1

Purpose

Enter page purpose here. Describe the objective of this page and what it aims to achieve.

2

Risk Addressed

Enter the key governance, security, or privacy risk being managed by this control, recipe, or checklist.

3

Core Control

Enter the required control or governance action. State the mandatory expectation clearly.

4

Why It Matters

Explain why this matters to the organization, stakeholders, and mission. Keep it concise and outcome-focused.

5

Standards Alignment

NIST

ISO 42001

EU AI Act

SOC

Internal Policy

Select applicable standards.

6

Required Inputs

- List required inputs.
- Add additional inputs.
- Include sources, data, systems, or approvals.

7

Minimum Control Requirements

☐ Enter minimum requirement 1.

☐ Enter minimum requirement 2.

☐ Enter minimum requirement 3.

☐ Enter minimum requirement 4.

☐ Enter minimum requirement 5 (if applicable).

8

Enhanced Control Requirements

☐ Enter enhanced requirement 1.

☐ Enter enhanced requirement 2.

☐ Enter enhanced requirement 3.

☐ Enter enhanced requirement 4.

☐ Enter enhanced requirement 5 (if applicable).

9

Process Steps

1

Step 1

Describe the step.

→

2

Step 2

Describe the step.

→

3

Step 3

Describe the step.

→

4

Step 4

Describe the step.

→

5

Step 5

Describe the step.

10

Evidence / Artifacts

Required Artifact	Owner	Status
Add evidence artifact 1	Enter owner	Not Started
Add evidence artifact 2	Enter owner	In Progress
Add evidence artifact 3	Enter owner	Complete
Add evidence artifact 4	Enter owner	N/A

11

Related Templates

- [Template or Checklist Name 1](#)
- [Template or Checklist Name 2](#)
- [Template or Checklist Name 3](#)

12

Governance Notes

Add any implementation guidance, exceptions, assumptions, or additional notes here.

13

Approval / Sign-Off

Prepared by Enter name / role	Reviewed by Enter name / role	Approved by Enter name / role	Date MM / DD / YYYY
---	---	---	-------------------------------

How to Use This Template



Define the control
Capture purpose, risk, and control action.



Assign ownership
Identify owners, contributors, and stakeholders.



Document evidence
List required artifacts and upload or link evidence.



Review on schedule
Follow the review cycle and update as needed.

9. Executive Dashboard and Maturity Roadmap

Registered systems 5 1 pilot	% with owners 100% all named	Quarterly incidents 1 contained	Maturity score 2.6 / 5 managed
---	---	--	---

- The next jump should focus on logging coverage, formal review notes, and tighter change control.

Level	Label	What it looks like
1	Foundational	Policy exists but ownership and intake are inconsistent.
2	Managed	Owners, intake, registry, and baseline controls are in place.
3	Operationalized	Review cadence, monitoring, and evidence are routine.
4	Assured	Controls are tested, exceptions are documented, and leadership receives clear reports.
5	Optimized	Program is measured, improved, and scaled with confidence across business use cases.

Appendix A. Governance Glossary

- AI system:** Any tool, model, workflow, or agent used to generate outputs, recommendations, or actions.
- Agent:** An AI-enabled workflow that can take or suggest actions using tools, connectors, or instructions.
- High-impact use case:** A use case with meaningful financial, legal, HR, customer, or safety impact.
- Human oversight:** A defined review or approval step performed by an accountable human.
- Model drift:** A change in model behavior or performance over time that affects output quality or safety.
- Shadow AI:** AI usage outside approved tools, workflows, or review paths.
- Knowledge base:** The source material or repository used to ground AI responses.
- Prohibited use:** A disallowed use case or activity that requires an exception to proceed.

Appendix B. Standards alignment crosswalk

Toolkit area	NIST AI RMF	ISO 42001	EU AI Act themes
Ownership and governance	NIST Govern	ISO 42001 leadership and planning	EU governance and QMS themes
Risk tiering and use-case review	NIST Map / Manage	ISO risk assessment and controls	EU high-risk logic themes
Data handling and provenance	NIST Map / Measure	ISO data governance	EU data governance themes
Human oversight and decisions	NIST Govern / Manage	ISO operational controls	EU human oversight
Logging and incident response	NIST Manage	ISO monitoring and improvement	EU logging, robustness, cybersecurity

Appendix C. Evidence register

Artifact	Refresh cycle	Owner	Done when
AI policy	Annual or when materially changed	AI Governance Lead	Current version approved
Approved tools list	Monthly	IT / Governance	Current list published
Use-case intake records	Per use case	AI Governance Lead	All active use cases logged
Risk tiering worksheets	Per use case	Business Owner +	Tier rationale documented

		Governance	
System registry	Monthly	IT / Governance	Review date current
Vendor review records	Before production + annual	Procurement / Security	Renewals tracked
Monitoring review notes	Monthly / quarterly	IT / Security	Review notes retained
Incident reports and RCA	As needed	Security / Ops	Closed with lessons learned